Feedback to CEN 40000-1-3 (CRA)

Organization/individual	OpenSSF
Contacts	mneag@contractor.linuxfoundation.org; dwheeler@linuxfoundation.org
Date	07-Feb-2026

These comments apply to draft CEN 40000-1-3 “Cybersecurity requirements for products with digital elements - Part 1-3: Vulnerability Handling” (December 2025). Relevant materials include:

- Regulation (EU) 2024/2847 Cyber Resilience Act (CRA): https://eur-lex.europa.eu/eli/reg/2024/2847/oj
- Blue Guide, (EU) 2022/C 247/01: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A52022XC0629%2804%29
- “Understanding the European Union (EU) Cyber Resilience Act (CRA) (LFEL1001)” (slides): https://docs.google.com/presentation/d/1j3OlNz2k5rk9KRD8ZZz8xvsM_hyxqOioK4UUkJTWee8/edit

We’re especially concerned that this document never notes that if a vulnerability is found in reused component, the maintainer of the upstream component needs to be notified, and that any fixes in the component should also be shared upstream. This probably belongs in section 5.6.3.3. Modern applications are mostly reused components, so it’s vital to notify and work with the maintainers of those components. This is especially important for open source software, but it’s not limited to that case.

Section number	Type of comment (editorial, technical, remark)	Comments	Proposed change
Introduction (pg 5)	Editorial	The introduction paragraph 4 first sentence text “are expected … are expected” does not read well.. It would be better if the introduction included some phrases from the CRA, such as	Replace introduction paragraph 4 sentence 1 with “The rigor with which vulnerability handling activities are expected to be executed must

		phrases in CRA preamble's recitals 1, 10, and 46, so that it's easier to demonstrate that this standard is aligned with the CRA while also the result of multi-stakeholder discussion (in accordance with CRA recital 79).	adhere to a risk-based approach, determined by the risk (likelihood and impact severity) of a security failure to damage the health, security or safety of users, or to provide the ability to disrupt, control or cause damage to a large number of other products with digital elements through direct manipulation."
Introduction (pg 5)	Editorial	The phrase "X cannot be too prescriptive" can be interpreted as "X is not possible", but that is not what was meant. Rephrase this for accuracy.	Change "The horizontal standards for the Cyber Resilience Act cannot be too prescriptive" to "The horizontal standards for the Cyber Resilience Act are intended to avoid being unduly prescriptive"
1. Introduction (pg 5)	Editorial	Figure 1 is complicated and is never cited in the main document. Figure 1 is cited only in the paragraph above it in this introduction, and its sole purpose is to justify a simple, obvious point that doesn't require a figure at all. Yet the complex figure introduces many other concepts that are unexplained and unnecessary. This creates unnecessary confusion, as there is no connection between this figure and the phases highlighted below, and there is no connection with the CRA timelines either.	Remove figure 1, and replace the paragraph above it with the fairly obvious point it supports: "There is often a period of time between vulnerability discovery and the application of security updates by end users. The longer this period of time, the longer the window of opportunity for threat actors to exploit the vulnerability and to conduct a cybersecurity attack."
introduction	technical	There is no definition for "High-risk impact"; the term should be explained. Since this is the introduction and nowhere else, we propose defining it in the same paragraph (instead of adding a glossary definition that the user would have to hunt for). That sentence is long, so adding a sentence immediately after it seems sensible. One approach would be summarizing the CRA text, especially from articles 7 and 8 (the definitions for important/critical software in the CRA). However, the text here seems to be	Immediately after the sentence with "high-risk impact" add this sentence: By high-risk impact we mean the loss of confidentiality, integrity, or availability that could be expected to have (directly or indirectly) a severe or catastrophic adverse effect on organizational operations, organizational assets, individuals, other organizations, or national security interests.

		more general. So we instead created a proposed definition derived from multiple definitions at https://csrc.nist.gov/glossary/term/high_impact	
Introduction	technical	This term “due diligence” in this sentence is confusing: “Manufacturers implementing this document will be equipped to demonstrate due diligence in vulnerability handling, maintain product security over time, and support transparency and trust across the digital ecosystem.” The problem is that in the CRA the term “due diligence” has another meaning. The phrase “due diligence” is always used in the CRA to indicate evaluation of components sources from third parties. For example, 13(5): “... manufacturers shall exercise due diligence when integrating components sourced from third parties so that those components do not compromise the cybersecurity of the product with digital elements…” See also the introduction to article 25, as well as preamble points 21, 34, and 35. It’s confusing to use a term with a distinctly different meaning than its meaning in the CRA.	Replace ‘due diligence’ with ‘reasonable care’
1 (pg 7)	Technical	The scope is stated as “The document is intended to support compliance with the Cyber Resilience Act (CRA) Regulation (EU) 2024/2847, particularly the essential requirements outlined in Annex I, Part II.” However, the excessively narrow scope implied by this statement makes the document unsuitable for its intended audience. Nothing requires this document to ONLY include the text of annex I part II. Indeed, only including requirements from annex I part II would mean that this document would fail to meet its requirement that it “shall provide specifications for	Change the scope sentence from “The document is intended to support compliance with the Cyber Resilience Act (CRA) Regulation (EU) 2024/2847, particularly the essential requirements outlined in Annex I, Part II.” to “The document is intended to support compliance by manufacturers with all vulnerability handling requirements of the Cyber

		vulnerability handling processes, covering all relevant product categories, to be put in place by manufacturers of the products with digital elements." (Commission Implementing Decision, Annex II, 2.2, https://ec.europa.eu/transparency/documents-register/detail?ref=C(2025)618&lang=en). It's true that this standard must cover CRA annex I, part II, but that's not the same as ONLY including the subset of the CRA vulnerability handling requirements and text that are mentioned in annex I, part II. Many CRA vulnerability handling requirements are not in CRA Annex I part II. For example, CRA article 13(6) says, "Where manufacturers have developed a software or hardware modification to address the vulnerability in that component, they shall share the relevant code or documentation with the person or entity manufacturing or maintaining the component, where appropriate in a machine-readable format." Article 13(8) has support time requirements (typically 5 years), which implies the minimum time for vulnerability handling. These appear nowhere is Annex I part II, but these must be implemented for a manufacturer to comply with the CRA's vulnerability handling requirements. Users of this document will assume that it covers all CRA vulnerability handling requirements, even though it currently does not. That incorrect assumption is encouraged by other statements, such as the end of page 6 which claims something that should be true but currently is not: "Manufacturers implementing this document will be equipped to demonstrate due diligence in vulnerability handling, maintain product security over time, and support transparency and trust across the digital ecosystem." Therefore, there's a substantial risk that organizations following this document as written will not meet many CRA vulnerability handling requirements. If this document is supposed to support CRA vulnerability handling,	Resilience Act (CRA) Regulation (EU) 2024/2847 including those in article 13, article 14, and the essential requirements outlined in Annex I, Part II."

		it needs to actually cover CRA vulnerability handling requirements for its audience, and not artificially limit itself to Annex I Part II. To us the solution is clear: this standard should fully cover vulnerability handling as required by the CRA. That's what readers will expect, and what even the authors of this document sometimes appear to expect (as evidenced by the last sentence on page 6). Don't change the last sentence of page 6, instead, make that sentence true. That means that all the CRA requirements for vulnerability handling that apply to manufacturers must be unambiguously covered by this standard. Once that's done, the document will greatly increase the likelihood of adequate vulnerability handling by manufacturers (as was intended). In addition, the scope statement doesn't make it immediately obvious that the intended audience is manufacturers. This is implied by the sentences around it, and its emphasis on annex I part II, but it'd be much better if the scope statement itself made the intended user of the standard (manufacturers) manifestly clear.	
1 (pg 7)	Technical	Vulnerability handling is only PART of ensuring security. This claim, therefore, is excessive: "Implementing these requirements enables a manufacturer to ensure security is maintained throughout the product life cycle."	Change "Implementing these requirements enables a manufacturer to ensure security is maintained throughout the product life cycle." to "Implementing these requirements enables a manufacturer to rapidly remediate vulnerabilities in products."
3	general	After "ISO and IEC maintain terminology databases for use in standardization at the following addresses: — ISO Online browsing platform: available at http://www.iso.org/obp — IEC Electropedia: available at http://www.electropedia.org/ "	After "— IEC Electropedia: available at http://www.electropedia.org/" add: "Other sources that explain terminology are: — National Institute of Standards and

		It should also include the NIST and ISACA libraries, as these provide helpful information. Note that while ISACA formerly stood for “Information Systems Audit and Control Association” that is no longer true and it is simply a stand-alone acronym: https://www.isaca.org/resources/news-and-trends/isaca-now-blog/2021/acronyms-only-scratch-the-surface-of-what-isaca-stands-for	Technology (NIST) Computer Security Research Center (NSRC) Glossary: available at https://csrc.nist.gov/glossary — ISACA Glossary: available at https://www.isaca.org/resources/glossary ”
3.3 (pg 8)	Technical	The term “coordinated vulnerability disclosure” is a key term and deserves its own entry, not a mere sub-bullet under coordination. What’s more, the definition given here is far too vague to be useful. This definition might plausibly be met by a ransomware gang in the middle of its extortion process or a private reporting process implemented by a company who has no intention of ever fixing any vulnerability reported to it (but instead threatens legal action on those who publicly expose their malfeasance). I started with this definition: https://www.enisa.europa.eu/news/enisa-news/coordinated-vulnerability-disclosure-policies-in-the-eu but I changed “vendor” to “software maintainer” (not all software maintainers are vendors) and made it clear it’s an “opportunity”. The danger with the original definition is that it might be read as permitting software maintainers to never get around to fixing it, or delay fixing vulnerabilities by thousands of years, if it might cost a euro to fix it. The point is that in CVD the’s coordination and an opportunity to fix it, but CVD does not assume that the time to privately fix the vulnerability is unlimited.	Remove the note in section 3.3, and instead add a definition of CVD: Coordinated vulnerability disclosure (CVD): a process by which vulnerability finders work together and share information with the relevant stakeholders such as vendors and ICT infrastructure owners. CVD ensures that software vulnerabilities get disclosed to the public after the software maintainer has an opportunity to develop a fix, a patch, or a different solution. This opportunity often includes an “embargo period” - a limited time where the vulnerability information is not publicly known.”
3	Technical	The term “embargo period” is missing.	Add a definition of “embargo period”. Here’s a start:

			Embargo period: a temporary period of time during which details of a vulnerability are kept confidential and restricted to a limited set of stakeholders (e.g., vendors, reporters, researchers) to allow time to develop and test fixes or mitigations before the vulnerability becomes public, thereby minimizing risk to users and other stakeholders. An embargo period immediately ends when the information is made available to public, even if the intent was for it to extend to a later time.
4.2	Technical	This phrase in 4.2 might be incorrectly interpreted as manding the purchase of many copies of an ISO document to comply with this specification: “To enhance the multi-party essence of the CVD and to capture the complexity of the supply chain and multiple stakeholder involved in the coordinated vulnerability disclosure process this document has been augmented with ISO/IEC TR 5895:2022 [4].”	Modify the sentence “To enhance…” to say: “To enhance the multi-party essence of the CVD, and to capture the complexity of the supply chain and multiple stakeholders involved in the coordinated vulnerability disclosure process, this document has been augmented by citing as guidance ISO/IEC TR 5895:2022 [4].”
4.2	Editorial	Figure 2 does not clearly show the relationship between the standards. What is shown there is not obvious, at least not to someone who does not have a copy of the standards and is not intimately familiar with the contents (many manufacturers will not have seen them, since these are expensive documents).	The figure has labels at the bottom (Vulnerability Disclosure, Vulnerability Handling, Multi-party Vulnerability Disclosure) that define the standard “swimlanes”. Add info to each of the labels to make it clear that each refers to a standard and which standard is referenced, e.g., instead of “Vulnerability Disclosure” write “ISO/IEC 29147 - Vulnerability disclosure”.
5.2	Editorial	Using the term APP for Applicability conflicts with the widely used abbreviation of APP for Application. Use a different prefix to reduce confusion.	Use APL, APC or APY instead of APP as the prefix.
5.2.2.1	Editorial	The phrase “Manufacturers are normally responsible for conducting a risk assessment…” - the word “normally” invites	Remove “normally”, so the sentence reads “Manufacturers are responsible for conducting a

		consideration of exceptions where manufacturers are not responsible for risk assessments. If that's the case, that discussion is missing.	risk assessment…". If that is not always true, clarify the conditions under which is it not true.
5.2.2.1	editorial	I expect that the note "NOTE EDITORIAL NOTE: CEN-CENELEC JTC13/WG9 invites feedback from the national organizations on the approach for requirement enhancements to better support the risk based approach. " to disappear after the review	Delete that note
5.2.2.3	Editorial	Regarding this note: "NOTE Requirement Enhancement: Requirements marked with "RE" indicate risk-based enhancements that apply where the regulatory risk assessment determines that additional rigor is necessary." The note is helpful, but it needs to be clear we're talking about the whole document, and cite why this is correct.	Replace this sentence: "NOTE Requirement Enhancement: Requirements marked with "RE" indicate risk-based enhancements that apply where the regulatory risk assessment determines that additional rigor is necessary." Before "indicate" add "in this document", and before the full stop add "as noted in section 4.1" as a citation so the reader can verify that this was promised by the document itself. The result should be: "NOTE Requirement Enhancement: Requirements marked with "RE" in this document indicate risk-based enhancements that apply where additional rigor is necessary as noted in section 4.1."
5.3.2.1	Technical	"An additional important aspect covered is the testing strategy that should be defined to support effective and regular tests and reviews of its products" - does not specify the kind of testing. A manufacturer might have extensive functional	Recommend security testing and reviews: "An additional important aspect covered is the cybersecurity testing strategy that should be defined to support effective and regular tests

		testing that will do little to improve product security.	and security reviews of its products”
5.3.2.1	technical	This section begins with the statement, “A manufacturer establishes and maintains an internal vulnerability handling policy to clearly define...” The term “internal” implies “private” to many, and that raises many conflicts. This text appears to conflict with CRA annex II(2) which specifically requires that users receive “... where the manufacturer’s policy on coordinated vulnerability disclosure can be found”. In short, at least part of this policy MUST be made available to users, and presumably more must be made available to governments, which seems to counter the idea of it being “internal”. In addition, there is no obvious justification for why this policy MUST be internal (private); many organizations work in a transparent way and make much or all of this information available, and there is no obvious reason that should be forbidden. The requirement should be to create a policy; what’s internal is a different matter. There should be no implication that a policy cannot be shared with others.	Replace “an internal vulnerability handling policy” with “a vulnerability handling policy”. In addition, add this requirement per CRA II(2)[second part]: “[PRE-1-RQ-?] The manufacturer shall ensure that users will receive information on where the manufacturer’s policy on coordinated vulnerability disclosure can be found, and ensure that information will remain available at least to those users.”
5.3.2.2	Technical	Having SBOM as an input when creating a policy implies that the policy must be at least reviewed every time the SBOM changes, which is unnecessary and not practical. If that were true then the inputs should also include hardware BOMs, AI models, external interfaces, and the many other things that can influence/impact vulnerability handling. Input to policy requirements should be something higher level.	Replace “- Software bill of materials” with “- Product architecture” Replace “- 5.3.10” with “- Test and review plan per 5.3.10”
5.3.2.3	Technical	PRE-1-RC-02 recommendation about the target schedule only considers responsible, coordinated disclosure case. Manufacturers should be prepared for other forms of	Add something like “ - process for remediation of vulnerabilities which are disclosed outside of the

		disclosure as well, ones without embargo period.	established CVD channels, such as zero-days, leaked vulnerabilities, and all other vulnerabilities disclosed publicly”
5.3.2.3	technical	“[PRE-1-RC-01] An organizational framework should be created to support the activities defined in the vulnerability handling process as per [PRE-1-RQ-01].” - clarify if that organizational framework is publicly-available or internal ???	Add ‘publicly-available’ or ‘internal’
5.3.2.3	editorial	“[PRE-1-RC-02] A policy on vulnerability handling should include:” the transition between the previous requirement and this part is very abrupt and is not clear. The text of [PRE-1-RC-02] should more clearly show its relationship to the previous text.	Just before the colon in the text “A policy on vulnerability handling should include:” insert the text “, in addition to the requirements in [PRE-1-RQ-02]”
5.3.2.3	technical	The text “[PRE-1-RC-02] …— the roles and responsibilities that will be assigned to handle the potential vulnerabilities in the product” should only apply to manufacturers. As written this could be incorrectly read as requiring the manufacturer to identify the roles and responsibility of others outside their organization. There’s no reason to forbid including that information, if they happen to know it, but a manufacturer should only be held responsible for defining roles and responsibilities for which they have control. Manufacturers typically cannot dictate roles and responsibilities to other parties such as vulnerability reporters, uses, or governments.	Changethe bullet “the roles and responsibilities that will be assigned to handle the potential vulnerabilities in the product” to add the word “manufacturer’s” before the word “roles”
5.3.2.3	technical	PRE-1-RQ-4 says “For a timely resolution of the issues, a mapping of upstream interdependencies, including open source, is required…” I feel a policy is the wrong place for a mapping like this. These mappings can change from release to release, requiring	Remove PRE-1-RQ-04.

		frequent policy churn. In many cases, manufacturers would have a limited view of upstream interdependencies for commercial closed source software, outside of SBOMs. Whatever possible is already covered by SBOM, and this requirement makes no sense.	
5.3.2.3	general	Note 5 references a standard that costs about ~170 Euros/person. Many will not have access to it. The note's bullets lists a few headers, but no content. The note should provide a brief identification of key factors (6.5-6.8) for those who don't have access to the referenced document. It's not reasonable to include all the text, but summarized key examples will help those who don't access to the referenced document.	Replace NOTE 5 with: For additional guidance on role and responsibilities including definition of usual activities refer to EN ISO/IEC 30111:2020 [2], in particular these sections (we provide examples of some important issues here): — 6.5 Vendor CSIRT or PSIRT: A PSIRT is responsible for coordinating external (and possibly internal) vulnerability reports and acts as a single point of contact for external stakeholders such as vulnerability reporters, coordinators, and other manufacturers. A PSIRT should monitor public sources of vulnerability information, develop a single point for receiving vulnerability reports, and maintain communication with reporters. — 6.6 Responsibilities of the product business division: When potential vulnerabilities are reported to a product business division by the PSIRT, the product business division should work with the PSIRT to develop remediations. Product security contacts within business

			divisions should initiate the vulnerability handling process when a vulnerability is found and should escalate vulnerability reports to a PSIRT. — 6.7 Responsibilities of customer support and public relations: Customer support divisions should be able to handle and respond to security vulnerabilities reported by customers. Customer support should be prepared to respond to or escalate questions and requests concerning advisories. If a disclosed vulnerability is serious or widespread, public relations divisions should prepare for contact from news media. — 6.8 Legal consultation: Manufacturers may need legal review of proposed remediations and communications.
5.3.2.3	technical	These two bullet points are repeated between the recommendation and requirement: “ — measures to prevent premature disclosure of information about potential vulnerabilities before they are fixed, as defined in 5.3.6 — activities and criteria to define a target schedule for the remediation of the vulnerability, which depends on the embargo period, established and inflüenced by the complexity of the case by case situation with impacted upstream stakeholders, and on the criticality of the vulnerability and the product itself”	Avoid repeating the things between the requirement and the recommendation -> delete those two bullet points
5.3.2.3	technical	“where known and appropriate, it is important to list the downstream stakeholders that are using the product under scope” - downstream stakeholders term is	Remove this bullet point, as mostly it will not make sense. “Where known and appropriate” is too rare to bother saying this anyway.

		very confusing there. downstream stakeholders may mean manufacturers. if we refer to the users, it's impossible to create such a list for most PDEs	
5.3.2.3	technical	“the mapping of upstream stakeholders to support the component identification required by 5.3.8 and 5.3.9” - this makes reference to mapping of upstream stakeholders to the SBOM output. That may be incomplete. I would prefer to map it on the output of due diligence requirement from PT1	Align it with due diligence requirements from PT1 and create the full list of upstream stakeholders (taking into account that due diligence requirements are wider)
5.3.2.3	Technical	“[PRE-1-RQ-03] The effectiveness of the vulnerability handling process shall be monitored.” - by whom should it be monitored?	Clarify by whom it should be monitored
5.3.2.3	Technical	“NOTE 8 For additional guidance on ways to monitor the effectiveness of the vulnerability handling process, refer to EN ISO/IEC 30111:2020 [2], 7.2.” - we need the text for those guidelines and not go an buy a costly standard	Please introduce a text in alignment with that standard that could be very costly for companies just to read
5.3.2.3	Technical	“[PRE-1-RQ-04] For a timely resolution of the issues, a mapping of upstream interdependencies, including open source, is required to support the coordination and notification activities when a vulnerability is discovered.” - above this request was under a recommendation; here is transformed into a requirement. Why? It is just inconsistent. Moreover, we need to understand how deep we need to go with this mapping - based on SBOM or on due diligence outcome	Remove this requirement
5.3.2.3	Technical	“[PRE-1-RQ-05] A policy on vulnerability handling shall support all the activities that are defined in the vulnerability disclosure policy, as described in 5.3.3.” it is very related to the pre-1-rq-1	Combine pre-1-rq-5 with pre-1-rq-1
5.3.2.4	Technical	“- list of the upstream stakeholders”	Remove this output

		this is a duplication of efforts if separate from due diligence and SBOM creation	
5.3.2.4	Technical	"— Data collection on target with the schedule remediation activities" this does not make any sense here. it should be made available once a vulnerability is detected and its remediation steps are assessed	Remove this output
5.3.2.4	Technical	"Existence of a list of upstream stakeholders linked to the components integrated into the product with a completeness check using the SBOM" duplication of efforts moreover this should not be connected to SBOM but more to the due diligence process	Remove this criteria
5.3.3.1	Technical	The phrase "agreed-on" is misleading here, as such agreements do not always happen. There is a long-standing tension on how long an embargo period should be. Some manufacturers may want the time to be 5-10 years or go to infinity, since this indefinitely delays or eliminates the costs of developing and deploying a fix to the defect. Some reporters may want a release in a few days or weeks, since this provides a faster fix for them (as they are often also users) and can provide faster credit. If the time period is too long or unending, there's reduced incentive for a manufacturer to fix it, and the public will be unaware of the risks that it is taking. While 90 days is a common embargo period for software, that's not always long enough, and in other circumstances it's unnecessarily long (increasing the risk of attack). It's difficult to make a single time period work for all situations. It's more important that there be some time, and that the manufacturer and reporter both know when that time will end. They might	Modify "In addition, to prevent attackers from gaining early access to sensitive information, reporters typically notify manufacturers privately, and refrain from public disclosure until a fix is available after an agreed-upon embargo period has passed." to instead say: "In addition, to prevent attackers from gaining early access to sensitive information, reporters typically notify manufacturers privately, and refrain from public disclosure until a fix is available or after an embargo period has passed. Manufacturers, reporters, and other stakeholders are strongly encouraged to come to an agreement on the embargo period, but if such an agreement cannot be made, at the least all parties should be made aware of when one of the parties will make the information

		not manage to agree on what the embargo period will be.	public.”
5.3.3.1.	General	This section should make it clear that the policy should identify the data desired in a vulnerability report. Reference the https://csirtsnetwork.eu/homepage?tab=cvd that includes the information that a report should include	The policy should also ensure that reporters know what information is desired in a vulnerability report. A useful example is the Coordinated Vulnerability Disclosure Policy of the European Union CSIRTs network, https://csirtsnetwork.eu/homepage?tab=cvd
5.3.3.3	Technical	The policy should require that reporters learn what they are expected to report. If reporters aren’t told, recipients may have inadquate information to work from. Reporters might not provide that data, and the manufacturer can’t force them to, but making expectations clear is helpful. This list is derived from https://csirtsnetwork.eu/homepage?tab=cvd	After the text of [PRE-2-RC-02] “A vulnerability disclosure policy should include following elements: .... 9.3.” add a new recommendation: [PRE-2-RC-?] “A vulnerability disclosure policy should ensure that reporters are requested to include at least the following elements in vulnerability reports: 1. Product where the vulnerability is found (preferably using at least one machine-processable identifier) 2. The version of the product on which the vulnerability is present, or the specific configuration of the product that is vulnerable 3. Discovered weakness category (such as a CWE) 4. The severity of the vulnerability (e.g., using CVSS to calculate) 5. A detailed description of the vulnerability,

			including the following information: - A summary of the vulnerability - Required steps to reproduce the vulnerability - Required configuration to reproduce the vulnerability - Possible mitigation measures for the vulnerability 6. Potential impact of the vulnerability 7. Whether the vulnerability has already been reported to (other) manufacturers 8. Whether a request for a CVE number or similar identifier has been made 9. Contact information of reporter, including secure communication options (PGP fingerprint, etc.) 10. Any other important information related to the discovered vulnerability This is per the Coordinated Vulnerability Disclosure Policy of the European Union CSIRTs network, https://csirtsnetwork.eu/homepage?tab=cvd
5.3.2.3	Technical	There seems to be a circular dependency between PRE-2-RC-03 (section 5.3.3.3) and PRE-1-RQ-02 (section 5.3.2.3). PRE-1-RQ-02 requires defining a “target schedule	Update PRE-1-RQ-02 to set up a default, severity-based, target schedule.

		for remediation development" that depends on the embargo period and is a part of vulnerability handling policy that is an input into CVD policy, which talks about defining embargo periods in PRE-2-RC-03. In many cases there will be multiple target schedules depending on various factors.	In PRE-1-RQ-02 change "a target schedule for remediation development" to "target schedule(s) for remediation development including at leaste a default schedule and perhaps alternatives based on severity, complexity, likely embargo periods, and other factors" (See also the 5.3.3.3 comment about updating PRE-2-RC-03 to modify previously established schedule based on agreement (or lack of it) established during CVD).
5.3.3.3	Technical	There seems to be a circular dependency between PRE-2-RC-03 (section 5.3.3.3) and PRE-1-RQ-02 (section 5.3.2.3). PRE-1-RQ-02 requires recommends defining a "target schedule for remediation development" that depends on the embargo period and is a part of vulnerability handling policy that is an input into CVD policy, which talks about defining embargo periods in PRE-2-RC-03. The emphasis should be on the embargo period (if one was agreed to) for CVD. Even if the vulnerability is fixed, other stakeholders may need time to address things (as agreed on by the embargo period), and if the information is public, "not disclosing" is likely to be pointless. Also, some manufacturers may choose to not fix even easily-fixed vulnerabilities; such manufacturers cannot expect that they can indefinitely hide the existance of vulnerabilities from their users and society.	Modify PRE-2-RC-03, replacing "A disclosure strategy should be in place to ensure that the information on vulnerability is not disclosed before it is addressed." With "A disclosure strategy should be in place to ensure that the information on vulnerability is not publicly disclosed before the embargo period ends (if one was agreed on) or the key information is already public."
5.3.3.3	general	Reference OpenSSF guidelines: https://github.com/ossf/oss-vulnerability-guide/blob/main/maintainer-guide.md#readme	After "[PRE-2-RQ-01] A policy on coordinated vulnerability disclosure (CVD) shall be created, published in an accessible format and adhered to." Add a "NOTE: Additional guidance may be

			found in “Guide to implementing a coordinated vulnerability disclosure process for open source projects” https://github.com/ossf/oss-vulnerability-guide/blob/main/maintainer-guide.md#readme
5.3.3.5	Editorial	In “Evidence of the policy on coordinated vulnerability disclosure that include agreements or definition of parameters…” it is unclear what agreements this is talking about. Copies of actual agreements with PII of reporters should not be expected to be entered into evicence for assessment.	Replace “Evidence of the policy on coordinated vulnerability disclosure that include agreements or definition of parameters…” with “Evidence of the policy on coordinated vulnerability disclosure that include sample agreements (or templates) between involved parties or definitions of parameters…”
5.3.4.3	Technical	PRE-3-RQ-01: “shall be considered” does not make sense as a requirement. What does it mean to be required just to think about it, especially in context of operational security.	In [PRE-3-RQ-01] replace “Limiting access to non-public vulnerability information on a need-to-know basis shall be considered.” with “Access to non-public vulnerability information shall be granted on a need-to-know basis to those who may be able to aid in its remediation and take steps to avoid revelation to those likely to exploit the vulnerability.””.
5.3.4.3	General	PRE-3-RQ-01 “Limiting access to non-public vulnerability information on a need-to-know basis shall be considered.” uses the security term of art “need-to-know” that probably won’t be understood well by some readers. Clarify its meaning inline.	Replace PRE-3-RQ-01 text with “Limiting access to non-public vulnerability information on a need-to-know basis (that is, to individuals whose roles explicitly require such access) shall be considered.”
5.3.5 [PRE-4] On-going	Editorial	The statement “The purpose of this phase is to maintain regular communication channels during the vulnerability handling activities with relevant stakeholders…” claims that	Change “The purpose of this phase is to maintain regular communication channels…” to “It is vitally important to maintain on-going

communication		on-going communication is a “phase” - but it really isn’t. A “phase” implies a time sequence or time period. Instead, on-going communication should simply occur.	communication during vulnerability handling to maintain regular communication channels…”
5.3.5 [PRE-4] On-going communication	Technical	Add a clear requirement for negotiation of the embargo period for a specific vulnerability between reporters, manufacturers, and other stakeholders, if it is not publicly known. In addition, make it clear that sometimes this negotiation will. An embargo period is mentioned several places, such as 5.3.3.3 notes 6 and 8. However, a reporter is typically under no obligation to obey an embargo period unilaterally set by a manufacturer. It’s best practice to try to get agreement on the embargo period among all parties. However, if the manufacturer wants a long period, they often can’t stop the reporter from making it public sooner, and the manufacturer often has a financial incentive to never fix it (leaving the public at risk). If they can’t gain agreement, they should at least be aware when the other party will make it public.	Add a new section about attempting to negotiate an embargo period, and that sometimes this negotiation will fail. Before “5.4.6 [RCP-5] Coordinator involvement” add a new section on negotiating embargo periods. 5.4.X Embargo period negotiation 5.4.X.1 General The purpose of this phase is attempt to negotiate an embargo period between the reporter, manufacturer, and any other stakeholders to reduce the number of attackers who have information about the vulnerability before there has been time to fix it. This standard does not mandate a specific timeframe, as the appropriate period depends on many factors, but a common embargo period is 90 days long. Ideally all parties would agree on the amount of time, but if they do not, it’s useful for all to know when the information will be made public. If the information is already public, there is typically no point in having an embargo period. 5.4.X.2 Input - Vulnerability information from 5.4.3

			- List of potentially impacted software components with related vulnerability information - List of potentially impacted hardware components with related vulnerability information 5.4.X.3 Requirement [RCP] An embargo period (or the fact that there will not be one) will be discussed between stakeholders and acknowledged; ideally all stakeholders will agree on the embargo period. NOTE: A common embargo period time is 90 days, but there is no “best” amount of time as there are many factors involved in any specific vulnerability. Faster responses are generally better (since they reduce the time attackers can find or learn of the problem), but if there’s too little time to fix it there’s a risk that the remediate will not work properly or cannot be deployed in a timely way to all users. 5.4.X.4 Output - An acknowledged embargo period or acknowledgement that there will not be one. 5.4.X.5 Assessment criteria - Identified emargo period or that there will not be one, ideally agreed on by all stakeholders

5.3.5.3	Technical	There should be a “single point of contact” for enabling users to communicate vulnerabilities. The CRA 13(17) says, “For the purposes of this Regulation, manufacturers shall designate a single point of contact to enable users to communicate directly and rapidly with them, including in order to facilitate reporting on vulnerabilities of the product with digital elements.” CRA II(2) says, “[PDE shall be accompanied by] the single point of contact where information about vulnerabilities of the product with digital elements can be reported and received, and where the manufacturer’s policy on coordinated vulnerability disclosure can be found”	Add a new requirement before the others in this section: [PRE-4-RQ-01] A single point of contact shall be identified to enable users to communicate directly and rapidly with the manufacturer, including to facilitate reporting on vulnerabilities of the product. The product shall be accompanied by the information how to learn of the single point of contact where information about vulnerabilities of the product with digital elements can be reported and received, and where the manufacturer’s policy on coordinated vulnerability disclosure can be found.
5.3.6.3	Editorial	“support 5.4.2can.” makes no sense	Remove extraneous “can” in “5.4.2can”
5.3.6.3	Technical	[PRE-5-RC-02] says: “Secure communication methods should support confidentiality and message integrity. EXAMPLE — web-based forms or applications using TLS (HTTPS) — e-mail encryption and signing using S/MIME or OpenPGP NOTE 3 For additional guidance on secure communication, refer to EN ISO/IEC 29147:2020 [3], 5.8.” These examples are inadequate. TLS (HTTPS) is certainly used and should be listed. However, only a small number of people will use S/MIME or OpenPGP, so while it’s fine to leave it in, by itself they are inadequate as practical examples. Adding DANE (DNS-based Authentication of Named Entities) wouldn’t help, since DANE depends on DNSSEC which also isn’t widely deployed.	Under: “— e-mail encryption and signing using S/MIME or OpenPGP” Add: — email transport encryption, e.g., using MTA-STS (Mail Transfer Agent Strict Transport Security) or STARTTLS (Start Transport Layer Security) — Signal Protocol

		I recommend adding additional examples so that users won't mistakenly believe that TLS is the only practical option. At the least add email transport encryption. MTA-STS is supported by Gmail and some other major problems. STARTTLS (Start Transport Layer Security) is widely available; it does not counter active attacks, but it counters passive attacks and it's definitely an improvement over the exposed emails that would happen otherwise. In addition, the Signal protocol is used by many to discuss vulnerabilities; it supports voice and videochat, and is used in the Signal app, WhatsApp, and Messenger. We need to make it easy for users to use encrypted channels, as that reduces the information easily available to attackers.	
5.3.6.3	Technical	5.3.6 contains no requirements, only recommendations for most manufacturers, and PRE-5-RQ-01-RE is a requirement enhancement that exists without a requirement. Attackers look for insecure communication mechanisms so that they can get non-public vulnerability information early. Don't make it easy for attackers. Today secure communication mechanisms are easily available. There's no reason supporting them should only be a "should" per [PRE-5-RC-01] (Secure communication mechanisms should be provided throughout the activities of receiving and communicating vulnerability information or reports). Require manufacturers support at least one (e.g., TLS or STARTTLS email). Reporters may choose to use another communication mechanism, but it's important that manufacturers provide at least one secure communication mechanism.	PRE-5-RQ-01-RE should be made a requirement on all. Change enhancement [PRE-5-RQ-01-RE] to be a simple requirement on all as [PRE-5-RQ-01]. Also, the last word of the current enhancement ("can") seems like an extra and should be deleted.
5.3.6.4	Technical	The required output assumes that secure communication methods will be used but reporters or other external stakeholders are not obligated to use manufacturer's secure	Change Output to - Documentation on the secure communication mechanisms available

		communication methods and a manufacturer can't force external parties to use provided secure communication methods. This output might not be achievable in all cases at no fault of manufacturer. Evidence of communication should not include any PII.	- Evidence of secure communication, if used, with PII redacted
5.3.5.6	Technical	Similar to 5.3.6.4, a manufacturer can't force anybody to use secure communication channels, even if available. Manufacturers should not be assessed on things they have no control over.	Change "If reports shave been submitted, evidence exists that secure communication with stakeholders has been performed" to If reports have been submitted, evidence exists that secure communication with stakeholders has been performed, or that it was attempted in case a secure communication channel could not be established"
5.3.7.3	Technical	The key here is that a product is not just identifiable but uniquely identifiable. Identification is not useful if there are multiple versions of something with the same identifier.	Change PRE-6-RQ-01 from "A product shall be identifiable by providing at least the following information" to "A product shall be uniquely identifiable by providing at least the following information"
5.3.7.5	Editorial	Assessment criteria should be updated for uniqueness to match 5.3.7.3	Change "Evidence of product identification" to "Evidence of unique product identification"
5.3.8 and 5.3.9	Technical	There should be a definition of "component" in context of these sections. Without a definition, the requirements are too vague, which will lead to invalid assumptions and inconsistencies. Is software component down to file level, library level, etc.? A hardware component could be a board, chip, resistor, etc. Definitions should be, at the minimum, added to section 3 with additional clarifications in 5.3.8 and 5.3.9.	Add a definition of component. Here's our proposed definition: Component: A part of a larger system, made up of Software, Hardware, and/or Firmware, which is integrated with, integrated into, or packaged with manufacturer's Product or Offer.

5.3.8.3 NOTE 3 and [PRE-7-RQ-07-RE]	Editorial	NOTE 3, [PRE-7-RQ-07-RE], and several other locations uses the term “suppliers” even when they appear to include open source software. Open source projects often object to being referred to as a supplier; see “I am not a supplier” by Thomas Depierre (31 Dec 2022) https://www.softwaremaxims.com/blog/not-a-supplier. The problem is that the term “supplier” (as well as “vendor”) falsely implies a contractual arrangement. Such arrangements do not normally exist with an open source software project. Consider using a more neutral term instead like “source” as suggested in https://openssf.org/blog/2023/04/17/distinguish-between-source-and-vendor/	In NOTE 3: Change “suppliers” to “sources (including suppliers)” In [PRE-7-RQ-07-RE]: Change “supplier” to “source (such as a supplier)”
5.3.7.3 [PRE-6-RQ-02]	Technical	This lists the software Hash Identifier (SWHID) but fails to include the more common software identifier “package URL (pURL)” and “Common Platform Enumeration (CPE)”. Add them as an option as well.	Under “software Hash Identifier (SWHID)” add lines that say “package URL (pURL)” and “Common Platform Enumeration (CPE)”
5.3.8.3 [PRE-7-RQ-01]	Technical	[PRE-7-RQ-01] mandates that “All software components contained in the product shall be identified and documented.” Yet this appears to directly contradict the CRA Annex I(II)(1), which expressly only requires that all *top-level* dependencies be identified. The text of “[PRE-7-RQ-03]” doesn’t help; it says that SBOMs only need to include the top level, yet due to PRE-7-RQ-01 the manufacturer must identify everything anyway. This document should not contradict the CRA, nor should it add general requirements that were expressly stated as not being requirements by the CRA. The CRA focuses on the top-level dependencies, and while it encourages more, it expressly does not require a full transitive closure. Full transitive closures becomes increasingly difficult as systems	Remove [PRE-7-RQ-01] and anything else that claims that all components are always transitively identified for all software. Modify “[PRE-7-RQ-03] An SBOM shall be drawn up, including at least the top-level dependencies that are contained in the product, as identified in [PRE-7-RQ-01].” to replace it as: [PRE-7-RQ-?] An SBOM shall be drawn up, including at least the top-level dependencies that are contained in the product.”

		get large. They also become legally problematic; when a system integrates an external component, the component provider might not provide a full list (or any list) of its subcomponents. PRE-7-EQ-03-RE adds transitive closures for higher risk cases, in contradiction to the CRA. That said, at least that's limited to high risk items, and that's more justiable. In contrast, this requirement PRE-7-RQ-01 isn't limited to that special case, but imposes requirements expressly not required by the CRA. This is also in contradiction with PRE-7-RQ-03.	
5.3.8.3 [PRE-7-RQ -02]	Technical	This list of component information should be for the SBOM. There shouldn't be a separate "list of components"; that IS the SBOM. The component information should include at least the broadly used list from the NTIA SBOM Minimum Elements <https://www.ntia.gov/sites/default/files/publications/sbom_minimum_elements_report_0.pdf>. They are currently missing several key pieces of data, therefore anyone following this guidance will be at a deficit to identify vulnerabilities within components of a product with digital elements, adding latency to their incident response. It's important to include machine-processable unique identifiers. A widely-used approach are package URLs (pURLs), which should at least be mentioned here (as they are mentioned later). NITA has Supplier Name, Component Name Designation, and Version of the Component, which seem to be covered here under different names. Two that are missing from the NTIA minimum elements specific for components are: ● Other Unique Identifiers Other identifiers that are used to identify a component, or serve as a look-up key for	These are not components of the "list of components" of [PRE-7-RQ-01], but are actually the data for the SBOM components. Add this data for the components: ● Other Unique Identifiers - Other identifiers that are used to identify a component, or serve as a look-up key for relevant databases. Examples include package URL (pURL) and Common Platform Enumeration (CPE). ● Dependency Relationship - Characterizing the relationship that an upstream component X is included in software Y.

		relevant databases. ● Dependency Relationship Characterizing the relationship that an upstream component X is included in software Y. The other elements of the NTIA minimum elements are metadata for the SBOM itself, and are discussed in another comment: ● Author of SBOM Data The name of the entity that creates the SBOM data for this component. ● Timestamp Record of the date and time of the SBOM data assembly.	
5.3.8.3 [PRE-7-RQ -03-RE]	Technical	[PRE-7-RQ-03-RE] says, “All the software components identified in [PRE-7-RQ-01] shall be drawn up in the SBOM to detect transitive dependencies when technically feasible.” The phrase “technically feasible” is a strong claim; many things are feasible with billions of euros. This should be recommendation not a requirement.	Change “technically feasible” to “practically and economically feasible” Replace shall with should. Transform RQ into an RC.
5.3.8.3 Note 4	Technical	Instead of ISO/IEC 27036/3:2023 we would recommend to reference BSI TR-03183-2 https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/Publications/TechGuidelines/TR03183/BSI-TR-03183-2_v2_2_0.pdf?__blob=publicationFile&v=9	Change the reference or add the supplementary reference to BSI doc
5.3.8.3 [PRE-7-RQ -03-RE]	Editorial	The phrases “Version” and “Timestamp” are unclear. Version and Timestamp of what? Even “SBOM Author” isn’t adequately clear. If properly understood these should help ensure that the SBOM data covers the minimum elements documented here: <https://www.ntia.gov/sites/default/files/publications/sbom_minimum_elements_report_0.pdf>. But this only works if the	Here change: “Version” to “Version of SBOM” “Timestamp” to “Timestamp of SBOM” “SBOM Author” to “Author of SBOM”

		fields are clearly stated.	
5.3.8.3 NOTE 7	Editorial	NOTE 7 says, “Some of the widely used machine-readable formats by software ecosystem stakeholders to generate and consume SBOMs are, for example:” This text is misleading. Many software ecosystems have specialized formats that identify software components but only work within their specific ecosystem, and thus, struggle with larger systems that use technologies from multiple ecosystems. The advantage of the listed specifications is that they work across ecosystems.	Change: “Some of the widely used machine-readable formats by software ecosystem stakeholders to generate and consume SBOMs are, for example:” To: “Some of the widely used machine-readable formats to generate and consume SBOMs that can work across ecosystems are, for example:”
5.3.8.3 [PRE-7-RC -01]	Technical	The draft is recommending fixing errors in SBOMs but this should really be a requirement, not an optional recommendation. Adding new details could be kept as recommendation.	Revise PRE-7-RC-01 as “When substantive new details about the identified components are detected, a revised SBOM should be issued” Create PRE-7-RQ-0X: “If a need to correct a substantive error in existing SBOM is discovered, a revised SBOM shall be issued”
5.3.8.3 [PRE-7-RQ -04] Note 7	editorial	“- CycloneDX”	Add the link for CycloneDX standard https://ecma-international.org/publications-and-standards/standards/ecma-424/
5.3.8.3 NOTE 15	Technical	NOTE 15 says, “In certain development models, such as those involving the integration of individual code snippets from open-source projects, it is not possible to include the hash and the corresponding algorithm in the SBOM, as no complete artefact from the original component exists.” It is sometimes possible to include the hash of the origin, even though it’s only a portion, so that problems in the origin can be	Change Note 15 to: In certain development models, such as those involving the integration of individual code snippets from open-source projects, it is not possible to include the hash and the corresponding

		checked.	algorithm of the entire component in the SBOM, as no complete artefact from the original component exists. In such cases, it may be useful to include the hash and algorithm of the full originating component, with an indicator that only a portion was used, in case a vulnerability was found in the original. However, in many cases this information is not available.
5.3.8.4 Output	Technical	This has “Identified software components” separate from “Software Bill of Materials (SBOM)”, but these are the same thing. Just list SBOM, and ensure that only the top-level dependencies are required to be in the SBOM as stated by the CRA Annex I(II)(1). Throughout the document there’s an artificial separation of “list of components” from “SBOM”, but adding the phrase “list of components” does not invalidate the express statement in CRA Annex I(II)(1) that while having more is encouraged, only the top level of components are required in the SBOM. This document should abstract away the vulnerability-identification process so that the higher-level requirements are what matters. In this case, there should be a mechanism for determining, given a vulnerability report, if it applies to their product. A comparison with a list of components (or SBOM) is just one way this could be implemented. This will require a lot of changes throughout this document, as this presumption of having a fully transitive list of components (that contradicts the CRA) is pervasive.	Remove “Identified software components” here and elsewhere.
5.3.9.1	technical	“This clause describes the activities for identifying the hardware components used in the product that may affect its cybersecurity. The purpose of this identification is to enable effective vulnerability…” implies that knowing all hardware components transitively, all the way down to atoms, is required. That’s not reasonable; not all the hardware	Change “This clause describes the activities for identifying the hardware components used in the product that may affect its cybersecurity.” by inserting “top-level” before “hardware”.

		components need to be identified. Please clearly state that, similarly with the software components, not all the hardware components need to be identified. Only top level components shall be required.	
5.3.9.3 [PRE-8-RQ -01] NOTE 1	Technical	The requirement to identify hardware components included in the product without defining the scope and level of identification is meaningless. This is especially true if a product is an integration of multiple third-party components, as the integrator often has no way to know information at deeper tiers (and they will often be subject to change). Consider something like a PC. Would components be the motherboard, graphics card, network card, etc., or CPU, GPU, RAM, or even lower? Does a manufacturer need to track the source and lot of every resistor and capacitor? Do they need to track the sources of conductive polymer materials used in some of the capacitors? Where does this end?, NOTE 1 points to Clause 3 for definition of hardware but that definition does not exist.	In [PRE-8-RQ-01] “Hardware components that are integrated in the product shall be identified and documented.” - just before the full stop, insert “, at least as the top-level component integrated into the product.”
5.3.10.3 [PRE-9-RQ -02]	Editorial	Spelling error	Change “product ocntext” to “product context”
5.3.10 Input [PRE-9-RQ -02]	Technical	Input and RQ-02 list test cases and methodologies as input and something that should be considered when the test plan is created. However, most of the time especially in regulated organizations, test plan is created first and test cases and methodologies are the implementation of the plan.	Change last item of the Input to “Product cybersecurity verification and validation including test cases and methodologies, if availalble” Change the last item of PRE-9-RQ-02 to “test cases and test methodologies, if available”
5.3.10.3 [PRE-9-RQ -03]	Editorial	The phrase “state-of-the-art” implies very modern and most recent ideas and methods, including fads and unproven research concepts and technologies that are so new that they	Change “state-of-the-art” to “state-of-practice”

		cannot be applied in many circumstances. This is not a document focusing on research, but on practical application. This phrase is incorrect or at least misleading. Do not use term “state-of-the-art” anywhere.	
5.3.10.3 [PRE-9-RQ -04]	Technical	Results of tests and reviews do not typically feed back into the plan. There needs to be a review cycle for the plan itself.	Change PRE-9-RQ-04 to something like “Effectiveness of the security test and review plan shall be assessed and updated periodically or when there are any changes in risk assessment or threat landscape”
5.3.11	Technical	The Mechanism for distribution is written from a software perspective, but what if a security update is in hardware? As written currently, it happens to work for hardware. “A mechanism shall be provided to distribute security updates in a secure manner” might mean tamper-evident shipping containers and using reputable shippers with proof of delivery, but reading the requirements, it is easy to forget the physical side.	Modify the last sentence of the first paragraph of General as “The update mechanisms can include both manual and/or (semi-)automatic updates, electronic delivery, or physical shipments of hardware components or installation media”
5.3.11.3 [PRE-10-R Q-02] + the Note	editorial	“[PRE-10-RQ-02] A mechanism for the distribution of security information for the product shall be provided. NOTE This includes mechanisms for providing advisories, release notes, installation information, and Notifications.” These two read together do not sound correct from my perspective - the text says there is a mechanism that includes mechanisms.	Replace the ‘mechanisms’ from the note with ‘methods’ (or perhaps ‘means’)
5.3.11.2 [PRE-10-R Q-03]	Technical	[PRE-10-RQ-03] says, “Where applicable, mechanisms for automatic distribution of security updates for product shall be provided.” However, it fails to clearly indicate legally-required aspects of this automatic distribution.	Append to the requirement text of [PRE-10-RQ-03] the following: “These automated mechanisms shall install the security updates within an appropriate timeframe, be enabled by default, have a clear

		By failing to clearly include the information on what is legally required by the CRA, there is an increased risk that manufacturers will fail to meet those obligations. In particular, annex I(I)(c) says, “ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them”	and easy-to-use opt-out mechanism, notify users of available security updates, and provide users the option to temporarily postpone security updates.”
5.3.11.3	Technical	There is a missing [PRE-10-RQ-??], “The environment for building and signing security updates shall be secured”. Currently we have [PRE-10-RQ-01] “A mechanism shall be provided to distribute security updates in a secure manner in accordance with prEN 40000-1-2:2025, 7.7.2.”. However, a secure update *distribution* system is meaningless if the originating build and signing system is subverted, as shown by successful attacks on Orion’s SolarWinds <https://www.linuxfoundation.org/blog/blog/preventing-supply-chain-attacks-like-solarwinds> and the subverted update of M.E.Doc, a Ukrainian tax accounting package developed by Intellect Service <https://en.wikipedia.org/wiki/2017_Ukraine_ransomware_attacks> <https://www.bbc.com/news/technology-40428967>.	Add missing [PRE-10-RQ-??], “The environment for building and signing security updates shall be secured”.
5.3.11	Technical	The current document fails to define minimum vulnerability handling support timeframes. Organizations are free to provide longer support, but certain minimums should be clearly stated. CRA 13(8) has support time requirements (typically 5 years), which implies the minimum time for vulnerability handling. Similarly, CRA 13(9) says “Manufacturers shall ensure that each security update… remains available after it has been	Add a new section (5.3.12?) after 5.3.11 5.3.X [PRE-X] Minimum vulnerability handling timeframes 5.3.X.1 General Manufacturers must plan on implementing vulnerability handling processes for a period of

		issued for a minimum of 10 years or for the remainder of the support period, whichever is longer." These requirements need to be part of this document. Otherwise organizations will claim they "comply" with the CRA while failing to meet these vulnerability handling requirements. They also need to be stated so that other contracts, laws, etc., can extend them further.	time subject to law, contract, and their support periods. 5.3.X.2 Inputs - Relevant laws and regulations - Contracts - Expected usage time - Public assertions by the organization about support 5.3.10.3 Requirement [PRE-X-RQ-01] Vulnerability handling shall be provided as required by laws, regulations, contracts, expected usage time, and public assertions by the organization about support. [PRE-X-RQ-02] Vulnerability handling for a product shall be at least five years or its expected use time, whichever is less. [PRE-X-RQ-03] All security updates shall remain available for a minimum of 10 years or for the remainder of the support period, whichever is longer. 5.3.10.3 Output - Compliant statement on vulnerability handling timeframes - Plan to ensure security updates remain available for at least the minimum time
5.4.1 General	technical	The text "vulnerability reports or information, the data are compared against the SBOM and the list of	After "Upon receiving relevant vulnerability reports or information," add "as well as due

		hardware components integrated in the product” is incomplete. As we still have the discrepancy between SBOMs and the list of components from due diligence report, I would add there also ‘due diligence reports’	diligence reports,” before “the data are compared against the SBOM and the list of hardware components integrated in the product.”
5.4.1 General	editorial	The text “Essential to this includes activities related to regular tests and internal reviews to proactively discover new vulnerabilities.” does not sound correct in English	Replace the text ““Essential to this includes activities related to regular tests and internal reviews to proactively discover new vulnerabilities.” with “Essential to this are activities such as regular tests and internal reviews to proactively discover new vulnerabilities.” If you don’t prefer that rewording, replace it with “Activities such as regular tests and internal reviews are essential for proactively discovering new vulnerabilities.”
5.4.2.3	Technical	The current document fails to include a requirement to test that the mechanism for reporting vulnerabilities actually works. That’s a mistake, since mechanisms might not actually work. At the least, require that the mechanisms be tested to work initially, and the relevant requirement enhancements (for higher risks) at least once a year. The later “verification” section describes how to verify vulnerability reports, but that doesn’t matter if the reports are never received. This is a requirement of CRA VII(6): “reports of the tests carried out to verify the conformity of the product with digital elements and of the vulnerability handling processes with the applicable essential cybersecurity requirements as set out in Parts I and II of Annex I;” Note that this requires tests, and reports of tests, of the vulnerability handling processes Similarly, CRA VIII(II)(3.4) says “the supporting evidence for	Add: [RCP-?-RQ-?] The publicly accessible reporting mechanism(s) shall be verified to work before release of the product, and this successful verification shall be recorded (including the date and who performed the verification). [RCP-?-RQ-?-RE] The publicly accessible reporting mechanism(s) shall be periodically verified, at least annually, to ensure that they continue to work, and this successful verification shall be recorded (including the date and who performed the verification).

		the adequacy of the technical design and development solutions and vulnerability handling processes. This supporting evidence shall mention any documents that have been used, in particular where the relevant harmonised standards or technical specifications have not been applied in full. The supporting evidence shall include, where necessary, the results of tests carried out by the appropriate laboratory of the manufacturer, or by another testing laboratory on its behalf and under its responsibility.”	
5.4.2.3 RCP-1-RQ-01	technical	The text “An additional consideration can be to include also a security.txt file in accordance with RFC 9116:2022 [15]” is likely to be confusing. First, I don’t know what “an additional consideration” really means. Is this a RFC 9116:2022 defines the widely-used website convention of using “.well-known/security.txt” to provide security contact information from a website. However, there’s also a related widely-used convention in open source software repositories to use “SECURITY.md” or “SECURITY.txt” at the top directory level to provide security contact information, which don’t follow the same conventions. Both are important, and when only mentioning one it might be confused for the other, so both should be mentioned here.	Replace “An additional consideration can be to include also a security.txt file in accordance with RFC 9116:2022 [15]” with this: “Manufacturers should use common mechanisms to provide security contact information, such as including this information in any web sites a .well-known/security.txt file in accordance with RFC 9116:2022 [15], and/or including this information in any publicly-visible source code repositories in a file named SECURITY.md or SECURITY.txt.”
5.4.4.1 General	technical	“This clause describes the activities for comparing the product's identified software components with incoming vulnerability information. Optionally, it is possible to automate this using the SBOM.” - I would also add the due diligence outputs, as these may be more complete than SBOMs. Also, SBOMs generally won’t be complete, so presuming this is fully automatable is unrealistic.	Replace “This clause describes the activities for comparing the product's identified software components with incoming vulnerability information. Optionally, it is possible to automate this using the SBOM.” With: “This clause describes the activities for employing due diligence outputs as well as comparing the product's identified software components with incoming vulnerability

			information. Optionally, it may possible to partly automate this using the SBOM.”
5.4.6.1	general	Please add a definition for ‘coordinator’. It is not clear from this document what that it is and the Note from RCP-5-RC-01 does not help at all. The proposal here uses ISO 29147 (with “where present” added to clarify that they’re not always present). If there’s a problem including the text of 29147 definitions directly in this document, then instead use one of the many other definitions available such as those from FIRST: https://www.first.org/global/sigs/vulnerability-coordination/multiparty/guidelines-v1.1 Or CERT: https://certcc.github.io/CERT-Guide-to-CVD/topics/roles/coordinator/	Add a definition for ‘coordinator’ in the definitions:? coordinator: where present, an individual or organization that performs coordination (ISO 29147) coordination: set of activities including identifying and engaging stakeholders, mediating, communicating, and other planning in support of vulnerability disclosure (ISO 29147)
5.4.6.3	Technical	The phrasing of Requirement [RCP-5-RC-01] is misleading. It says, “A coordinator should be assigned and involved in the vulnerability handling process, where appropriate.” In many cases this is not appropriate. In addition, this would be determined on a case-by-case basis for vulnerabilities of vulnerability categories; it’s only appropriate in some cases. Emphasize that the first question is whether the role is even appropriate; only then is one assigned and involved.	Rephrase Requirement [RCP-5-RC-01] as, “If it is determined that it would be appropriate to have a coordinator for handling a particular vulnerability or vulnerability category, a coordinator should be assigned and involved.”
5.4.7	General	Move this chapter “Performing regular tests” after 5.3.10 “Planning regular test and reviews”. Section 5.4 is about receipt of a vulnerabililty, which this chapter isn’t really about; this chapter about performing regular tests, which may occasionally discover a vulnerability to be fed into section 5.4.	Move this chapter “Performing regular tests” after 5.3.10 [PRE-9] Planning regular test and reviews

5.4.7	Editorial	A lot of testing can be performed without any impact on security. RCP-6 should be clarified to focus on security testing, not testing in general	Change “[RCP-6] Performing regular tests” to ‘[RCP-6] Performing regular security testing”
5.4.8	Editorial	There are many different kinds of reviews. The current title implies that this section covers all reviews, and it does not. Make it clear, from the title, that we are focusing on SECURITY reviews.	Change title from “Performing regular reviews” to “Performing regular security reviews”
5.4.8.1	Editorial	Section 5.4.8 is the section about security reviews. Section 5.4.7 was the section about security testing. Section 5.4.8.1 Generally, there should not need to have any language about security testing here, as that all belongs in the previous section	Remove language related to security testing from the General section. For example, move “This includes performing security tests throughout the product's support period.” in the above chapter, the actual 5.4.7
5.4.8.2 Input	Editorial	The phrase “state-of-the-art” implies very modern and most recent ideas and methods, including fads and unproven research concepts. This is not a document focusing on research, but on practical application. This phrase is incorrect or at least misleading.	Change “state-of-the-art” to “state-of-practice”
5.4.8.3	Editorial	FIx missing space.	Add a space after “refer to”
5.4.8.3	Technical	There is a disconnect between the assessment criteria and requirements. Section 5.4.8.3 RCP-7-RQ-02 requires periodic reviews (but not updates) of risk assessment, but the assessment criteria of section 5.4.8.5 is looking for updates to test and review plan, which are discussed in 5.3.10. The assessment of RCP-7 should be assessing compliance with the RCP-7 requirements.	Modify “[RCP-7-RQ-01] Security reviews shall be performed according to the security test and review plan” by inserting before the stop “, updating the plan as appropriate”
5.4.8.3	Technical	The wording of [RCP-7-RQ-02] is confusing. It never uses the	Change “[RCP-7-RQ-02] The assumptions and

		term “security review” even though the purpose of this section (5.4.8) is to provide requirements on security reviews. Currently this requirement instead uses the term “cybersecurity risk assessment”, an undefined term that occurs nowhere else in this document. Please use the same terminology everywhere for the same thing, and in particular, that requirements include the key term that they are placing requirements upon. In this case, say “security review” since that is the point.	all inputs of the product cybersecurity risk assessment shall be reviewed periodically (at least once a year), even if the product design does not change.” to: [RCP-7-RQ-02] The security review, including re-evaluation of its assumptions, shall be reviewed periodically (at least once a year), even if the product design does not change.
5.5.1 Note1	Technical	NOTE 1 currently says, “During Multi-party coordinated vulnerability (MPCVD) consider the guidance provided by ISO/IEC TR 5895:2022 [4], 9.2.” However, this ignores the widely-used guidance from FIRST, a leading organization that specializes in this topic. The FIRST documents provide real-world best practices and improved discussions for handling more complex situations involving multiple organizations. FIRST is the leading organziation on such topics, it is the organization’s primary focus. They’re also freely and publicly available to all. We would suggest replacing this citation, or at the least, adding this citation to the FIRST material	Replace: “NOTE 1 During Multi-party Multi-party coordinated vulnerability (MPCVD) consider the guidance provided by ISO/IEC TR 5895:2022 [4], 9.2.” With this text: NOTE 1 During Multi-party Multi-party coordinated vulnerability (MPCVD) consider the guidance provided by FIRST “Guidelines and Practices for Multi-Party Vulnerability Coordination and Disclosure” Version 1.1, Spring, 2020 https://www.first.org/global/sigs/vulnerability-coordination/multiparty/guidelines-v1-1
5.5.2.1	TechnicalTechnical	This section says, “This step ensures that only verified vulnerabilities proceed to the security risk assessment.” but this sentence is in direct contradiction with section 5.5.1, “NOTE 2 Whereas [VRF-1] Initial assessment and verification and [VRF-2] Vulnerability risk assessment are separated, all the activities listed can occur in parallel rather than in a sequential order.” It doesn’t matter if a vulnerability report is true if it’s also irrelevant. In some cases it’s easier to determine “even if this report is true it cannot cause harm”. Don’t mandate a specific order of events when a specific	Delete “This step ensures that only verified vulnerabilities proceed to the security risk assessment.”

		order isn't necessary.	
5.5.2.2	Technical	The reporter's identity and contact information, where available, are often critical. Some reporters send in endless slop; their reports need to be de-prioritized. Some reporters have excellent reputations, and their reports need to be prioritized. The contact information is needed if dialogue is to begin.	Add "- reporter's identity and/or contact information if available"
5.5.2.3 [VRF-1-RQ -01]	Technical	You can't know if you have enough information in a vulnerability report until you assess the vulnerability report.	[VRF-1-RQ-02] and [VRF-1-RQ-01] should be swapped.
5.5.2.3 [VRF-1-RQ -02]	Technical	In [VRF-1-RQ-02] you aren't just assessing the vulnerability, you're assessing the vulnerability report. Often you can't assess the vulnerability itself because the report lacks key information.	Change "An assessment of the vulnerability shall be performed." to Change "An assessment of the vulnerability report and the reported vulnerability shall be performed."
5.5.2.3 [VRF-1-RQ -02]	Technical	The "NOTE" of [VRF-1-RQ-02] has a list of blank items. I'm guessing this is from 30111. This needs to be replaced with some actual content. In addition, the introduction of the section has the list "valid, reproducible, and applicable" but that needs to support requirements somewhere. In particular, many developers are being increasingly overwhelmed by incorrect reports generated by AI systems that aren't reviewed by a human. E.g.: curl noted this here in: https://daniel.haxx.se/blog/2025/07/14/death-by-a-thousand-slops/ and his announcement that "We now ban every reporter INSTANTLY who submits reports we deem AI slop. A threshold has been reached. We are effectively being DDoSed. If we could, we would charge them for this waste of our time." AI is not always bad, e.g., https://daniel.haxx.se/blog/2025/10/10/a-new-breed-of-analyz	Place content here. Here's an alternative: - Determine if the vulnerability report is valid (is it true and really a vulnerability?), reproducible, and applicable to one or more supported products. - If it is already known, add any additional information to the already-known information on the vulnerability. - Reporter reputation, if known, can help in the initial estimate of validity. Organizations may choose to ignore reports from reporters who repeatedly provide invalid reports (for example, by repeatedly providing unreviewed "AI

		ers/ lists examples of valuable vulnerability reports from AI. The difference is that humans ensured the vulnerability reports were valid before submitting them.	slop”).
5.5.2.5	Technical	If a vulnerability is found to be not applicable or otherwise not valid, its severity will not be determined.	Change “Evidence exists that the severity has been determined” to “Evidence exists that the severity has been determined for applicable validated vulnerabilities”
5.5.3	Technical	During vulnerability handling, recipients may determine that the reported vulnerabilities are being actively exploited or represent security incidents in a way that may lead to mandatory reporting to government agencies. A new subsection is needed to clearly state this. Many CRA texts specifically require this: ● 14(1): “1. A manufacturer shall notify any actively exploited vulnerability contained in the product with digital elements that it becomes aware of simultaneously to the CSIRT designated as coordinator, in accordance with paragraph 7 of this Article, and to ENISA. The manufacturer shall notify that actively exploited vulnerability via the single reporting platform established pursuant to Article 16.” - note that 14(7) clarifies this further. ● 14(2): “For the purposes of the notification referred to in paragraph 1, the manufacturer shall submit: [early warning, notification, final report]” ● 14(3): “A manufacturer shall notify any severe incident having an impact on the security of the product with digital elements that it becomes aware of simultaneously to the CSIRT designated as coordinator, in accordance with paragraph 7 of this Article, and to ENISA. The manufacturer shall notify	Add a new section 5.5.2 (between the current 5.5.2 and 5.5.3): 5.5.X [VRF-X] Reporting of actively exploited vulnerabilities and severe incidents 5.5.X.1 General A vulnerability that is being actively exploited or represents a severe security incident may lead to obligatory reporting to external parties, including government(s). 5.5.X.2 Input — Verified vulnerability report, including an assessment of the vulnerability and severity. 5.5.X.3 Requirement [VRF-X-RQ-01] If it is determined that the vulnerability is being actively exploited, governments and/or other external parties shall be notified in the manner and time periods required by law and/or by contractual obligations.

		that incident via the single reporting platform established pursuant to Article 16." ● 14(4): "For the purposes of the notification referred to in paragraph 3, the manufacturer shall submit: [list]" ● 14(6): "Where necessary, the CSIRT designated as coordinator initially receiving the notification may request manufacturers to provide an intermediate report on relevant status updates about the actively exploited vulnerability or severe incident having an impact on the security of the product with digital elements." ● 14(8): "After becoming aware of an actively exploited vulnerability or a severe incident having an impact on the security of the product with digital elements, the manufacturer shall inform the impacted users of the product with digital elements, and where appropriate all users, of that vulnerability or incident and, where necessary, of any risk mitigation and corrective measures that the users can deploy to mitigate the impact of that vulnerability or incident, where appropriate in a structured, machine-readable format that is easily automatically processable…" We think 14(1) through 14(6) can be summarized as "report to governments & other organizations as required by law and contract", but 14(8) is specifically about reporting to users and thus is different. Note that this is different than reporting about a fix (handled in response). We recommend that the "actively exploited vulnerabilities" be listed as separate requirements from "incidents"; both involve vulnerability handling, but in some organizations these are handled by different teams or organizational divisions. Making these separate requirements will greatly simplify tracking and increase the likelihood that organizations will fully implement the requirements.	[VRF-X-RQ-01] If it is determined that the report represents a severe incident, governments and/or other external parties are shall be notified in the manner and time periods required by law and/or by contractual obligations. [VRF-X-RQ-01] After becoming aware of an actively exploited vulnerability, the manufacturer shall inform the impacted users of the product, and where appropriate all users, of that vulnerability or incident and, where necessary, of any risk mitigation and corrective measures that the users can deploy to mitigate the impact of that vulnerability or incident, where appropriate in a structured, machine-readable format that is easily automatically processable. [VRF-X-RQ-01] After becoming aware of a severe incident having an impact on the security of a product, the manufacturer shall inform the impacted users of the product, and where appropriate all users, of that vulnerability or incident and, where necessary, of any risk mitigation and corrective measures that the users can deploy to mitigate the impact of that vulnerability or incident, where appropriate in a structured, machine-readable format that is easily automatically processable.

5.5.2.1	Technical	Section 5.5.2.2 includes as inputs “List of software and hardware components, see sections 5.3.8 and 5.3.9”. This might lead the reader to incorrectly believe that the only kinds of vulnerability reports that can occur are reports about third-party components used in the product. That is not the intent, but the problem is that the reader might gain this misunderstanding. To prevent this misunderstanding, it’s important that the text in 5.5.2.1 make it abundantly clear that there are many different sources of vulnerability reports and that they can apply to externally-provided components, custom code, or custom hardware. This important, because the CRA expressly considers vulnerability reports from both internal and external sources. CRA 13(8) says “Manufacturers shall have appropriate policies and procedures, including coordinated vulnerability disclosure policies, referred to in Part II, point (5), of Annex I to process and remediate potential vulnerabilities in the product with digital elements reported from internal or external sources.”	After “The clause describes the initial assessment and verification of the vulnerability report. The primary objective of this phase is to assess the validity, reproducibility, and applicability of reported vulnerabilities.” insert this new text: “This applies to vulnerability reports from both external and internal sources, and whether or not the vulnerability report identifies a specific external component used in the product, custom software or hardware for the product, or does not make any such determination. Note that reports from external sources may use different systems than those from internal sources.”
5.5.3.3	Technical	Analysis of the impact of a component vulnerability can be quite expensive and time-consuming. In addition, it is sometimes difficult to be certain that a component vulnerability cannot become a a system vulnerability. In some cases it’s more effective to stop this analysis early, apply a security update of a component or update the component, then ship the product that uses the fixed or updated component.	Just before [VRF-2-RQ-04] insert this requirement: [VRF-2-RQ-?] The risk assessment of [VRF-2-RQ-01] need only be performed to the depth necessary to make a decision. If the decision is to update a component or fix a custom component in a manner that would fix the potential vulnerability, the process shall proceed as if the analysis determined that there was a vulnerability.
5.6.2.3	Technical	It’s possible that the costs of remediation are too high, especially if it’s been outpaced by other better products. In	Add new requirement:

		that case, they need to withdraw/recall the product. Sometimes organizations withdraw products! This needs to be clear, and it currently is not. This is specifically required by CRA 13(21): “From the placing on the market and for the support period, manufacturers who know or have reason to believe that the product with digital elements or the processes put in place by the manufacturer are not in conformity with the essential cybersecurity requirements set out in Annex I shall immediately take the corrective measures necessary to bring that product with digital elements or the manufacturer’s processes into conformity, or to withdraw or recall the product, as appropriate.”	[RMD-1-RQ-03] If the reported vulnerability in the product renders the product no longer in conformity with essential cybersecurity requirements, and the organization will not take the corrective measures necessary to bring that product or its processes into conformity, then the organization shall withdraw or recall the product as appropriate for situations where the essential cybersecurity requirements apply.
5.6.3.3	Editorial	This section’s requirement [RMD-2-RQ-02] uses the term “technically feasible’ without adequately defining the term. Notes 5 and 6 hint at aspects that might might matter, but aren’t a definition. There should be a clear definition “Technically feasible is…” Instead, we have this set of unclear statements: [RMD-2-RQ-02] Security updates shall be provided separately from functional updates, where technically feasible. NOTE 5 Technical feasibility: the degree to which the proposed system design and architecture can be implemented using available technology, within constraints such as cost, schedule, and performance. NOTE 6 Technical feasibility, can also consider operational feasibility, where the goal is to ensure the solution can be effectively integrated, maintained, and supported.	Add a definition of technically feasible. Here’s an example: Technically feasible: An action is technically feasible if it can be implemented using available production-ready technology within appropriate constraints such as cost, schedule, and performance, and can be operationally deployed to be integrated, used, maintained, and supported.
5.6.3.3	Technical	Currently, this document fails to note that if a vulnerability is found in a component, the maintainer of the (upstream) component must also be notified. It is CRITICAL that this be	Before “[RMD-2-RQ-01] The remediation shall be produced.” add:

		included. This is a key vulnerability handling activity required by the CRA as part of 13(6): “Manufacturers shall, upon identifying a vulnerability in a component, including in an open source-component, which is integrated in the product with digital elements report the vulnerability to the person or entity manufacturing or maintaining the component, and address and remediate the vulnerability in accordance with the vulnerability handling requirements set out in Part II of Annex I. …” It’s vitally important that this be included in this document. Often analysis will end up discovering a vulnerability in a component from a third party. In those cases, the component maintainer needs to be informed. Without this step, other products that use the component may remain vulnerable. This is especially important for open source software, but it’s not limited to that.	[RMD-2-RQ-?] If a vulnerability is identified in one or more integrated components that are separately maintained, including any open source component, the vulnerability shall be reported to the vulnerability handling process for those components and an attempt shall be made to coordinate a response.
5.6.3.3	Technical	Currently, this document fails to note that if a fix is made to an external component, the maintainer of the upstream component must also be provided with that fix. It is CRITICAL that this be included. This is a key vulnerability handling activity required by the CRA as part of 13(6): “... Where manufacturers have developed a software or hardware modification to address the vulnerability in that component, they shall share the relevant code or documentation with the person or entity manufacturing or maintaining the component, where appropriate in a machine-readable format.” Without this, the component maintainers may not have the resources to create a change, or may misunderstand the problem and create a change that doesn’t fully address the vulnerability. As a result of this failure to share the change, other products that use the component may remain vulnerable. This is especially important for open source software, but it’s not limited to that.	After “[RMD-2-RQ-01] The remediation shall be produced.” note 4, add: [RMD-2-RQ-?] If software or hardware modification(s) to address the vulnerability have been developed in components that are separately maintained, the relevant code or documentation shall be shared with the person or entity manufacturing or maintaining the component in a machine-readable format. If the components are open-source software, these changes to address the vulnerability shall be licensed, wherever practical, to permit integration into the component without change to the component’s licenses.

5.6.3.3 [RMD-2-RQ-01]	Technical	Does this requirement even need to be there? What if the decision was to defer because of low risk or other reasons. Manufacturers might find themselves in non-compliance at random moments depending on when the assessment takes place. Remediation might be scheduled or delayed for valid reasons. We don't see a value in explicitly stating that "remediation shall be produced" so baldly.	In RMD-2-RQ-01 after "The remediation shall be produced" insert "if the vulnerability severity warrants it"
5.6.4.3	Editorial	Note 3 says "full underlying component verification is performed by the supplier." but open source software projects generally do not consider themselves "suppliers". Many do have a kind of component verification (e.g., a test suite), but maintainers using them may wish to supplement this. In addition, this bald statement is not always true in reality, even for components from manufacturers. Finally, manufacturers are only responsible for their product, not everything that the components they use COULD do. Open source projects often object to being referred to as a supplier; see "I am not a supplier" by Thomas Depierre (31 Dec 2022) https://www.softwaremaxims.com/blog/not-a-supplier. The problem is that the term "supplier" (as well as "vendor") falsely implies a contractual arrangement. Such arrangements do no normally exist with an open source software project. Consider using a more neutral term instead like "source" as suggested in https://openssf.org/blog/2023/04/17/distinguish-between-source-and-vendor/	Change note 3 text "full underlying component verification is performed by the supplier." to "full underlying component verification is often done by the source, and if the component is supplied by a manufacturer, it is the responsibility of that manufacturer to make their product secure."
5.7.2.3 [RLS-1-RQ-01]	Technical	The "free of charge" might be difficult for hardware updates. Definitely agree with it for software, but for hardware updates that require physical shipment, should a manufacturer be allowed to charge reasonable shipping costs? It may be too	Add NOTE n after RLS-1-RQ-01 "For security updates that require physical distribution, manufacturers are allowed to charge for standard shipping costs."

		much burden for many otherwise, especially if long distance international shipment is required and the security update is physically heavy.	
5.7.3.3, Note 3	Technical	NOTE 3 says “Machine-readable format is specified in ISO/IEC 20153:2025 [17]” which implies that OASIS Common Security Advisory Framework Version 2.0 is the only permitted machine-readable format for this information. CSAF tends to require complex tooling and isn’t what everyone uses. This requirement as stated is excessive. In many cases, simpler approach are fine (e.g., if you just want a VEX, OpenVEX is much easier to work with).	Change “Machine-readable format is specified in ISO/IEC 20153:2025 [17]” to: Change “This document does not require any specific machine-readable format; an example of such a format is specified in ISO/IEC 20153:2025 [17].”
5.8.2.3 Requirement [PRA-1-RQ-01]	Technical	5.8.2.3 Requirement [PRA-1-RQ-01] says “Post-release actions shall be carried out, including: …” but nothing here suggests any effort to do root cause analysis to determine the cause of the vulnerability, identifying ways to reduce likelihood of recurrence, and considering changes to reduce the likelihood of recurrence. Mistakes are inevitable, but what we CAN do is learn from them to prevent future problems. In the long run THAT is what will make a difference. Yet that is nowhere mentioned here. That said, there are cases where root cause analysis doesn’t make sense (e.g., where the information necessary isn’t available), so this should be a recommendation and not a requirement.	Add to 5.8.2.3 a new recommendation as a post-release action: [PRA-1-RC-01] As a post-release action there should be an analysis to identify the root causes of the vulnerability and practical approaches that would reduce the likelihood or impact of similar vulnerabilities in the future. Where appropriate and practical, actions should then be taken to implement at least one of those approaches.
5.8.2.3 Requirement [PRA-1-RQ-01]	Technical	Sometimes vulnerabilities reveal a change in the fundamental risk assessment of the product, and so it needs updating. This is specifically required in CRA 13(7) “The manufacturers shall systematically document, in a manner that is proportionate to the nature and the cybersecurity risks, relevant cybersecurity aspects concerning the products with	Add to [PRA-1-RQ-01] the post-release action: - Where applicable, update the cybersecurity risk assessment of the products.

		digital elements, including vulnerabilities of which they become aware and any relevant information provided by third parties, and shall, where applicable, update the cybersecurity risk assessment of the products.”	
Annex ZA	Technical	This document fails to address many CRA vulnerability handling requirements, and instead only considers the subset of vulnerability handling in Annex I, Part 2. This document should identify all the CRA vulnerability handling requirements (including those in articles 13 and 14), and make sure those are listed here and mapped into the document. These CRA vulnerability handling requirements that are currently missing from the document include: ● 13(6): “Manufacturers shall, upon identifying a vulnerability in a component, including in an open source-component, which is integrated in the product with digital elements report the vulnerability to the person or entity manufacturing or maintaining the component, and address and remediate the vulnerability in accordance with the vulnerability handling requirements set out in Part II of Annex I. Where manufacturers have developed a software or hardware modification to address the vulnerability in that component, they shall share the relevant code or documentation with the person or entity manufacturing or maintaining the component, where appropriate in a machine-readable format.” ● 13(7) “The manufacturers shall systematically document, in a manner that is proportionate to the nature and the cybersecurity risks, relevant cybersecurity aspects concerning the products with digital elements, including vulnerabilities of which they become aware and any relevant information provided by third parties, and shall, where applicable, update	Add the other CRA vulnerability handling requirements to this table and map them. In other comments we have proposed resolutions to these points; when they are added, add them to this table.

		the cybersecurity risk assessment of the products." ● Article 13(8) has support time requirements (typically 5 years), which implies the minimum time for vulnerability handling. ● 13(9): "Manufacturers shall ensure that each security update, as referred to in Part II, point (8), of Annex I, which has been made available to users during the support period, remains available after it has been issued for a minimum of 10 years or for the remainder of the support period, whichever is longer." ● 13(17): "For the purposes of this Regulation, manufacturers shall designate a single point of contact to enable users to communicate directly and rapidly with them, including in order to facilitate reporting on vulnerabilities of the product with digital elements. / Manufacturers shall ensure that the single point of contact is easily identifiable by the users. They shall also include the single point of contact in the information and instructions to the user set out in Annex II. / The single point of contact shall allow users to choose their preferred means of communication and shall not limit such means to automated tools" ● 13(21) "From the placing on the market and for the support period, manufacturers who know or have reason to believe that the product with digital elements or the processes put in place by the manufacturer are not in conformity with the essential cybersecurity requirements set out in Annex I shall immediately take the corrective measures necessary to bring that product with digital elements or the manufacturer's processes into conformity, or to withdraw or recall the product, as appropriate." (These would be vulnerabilities.) ● 14(1): "1. A manufacturer shall notify any actively exploited vulnerability contained in the product with digital elements that it becomes aware of	

		simultaneously to the CSIRT designated as coordinator, in accordance with paragraph 7 of this Article, and to ENISA. The manufacturer shall notify that actively exploited vulnerability via the single reporting platform established pursuant to Article 16." - note that 14(7) clarifies this further. ● 14(2): "For the purposes of the notification referred to in paragraph 1, the manufacturer shall submit: [early warning, notification, final report]" ● 14(3): "A manufacturer shall notify any severe incident having an impact on the security of the product with digital elements that it becomes aware of simultaneously to the CSIRT designated as coordinator, in accordance with paragraph 7 of this Article, and to ENISA. The manufacturer shall notify that incident via the single reporting platform established pursuant to Article 16." ● 14(4): "For the purposes of the notification referred to in paragraph 3, the manufacturer shall submit: [list]" ● 14(6): "Where necessary, the CSIRT designated as coordinator initially receiving the notification may request manufacturers to provide an intermediate report on relevant status updates about the actively exploited vulnerability or severe incident having an impact on the security of the product with digital elements." ● 14(8): "After becoming aware of an actively exploited vulnerability or a severe incident having an impact on the security of the product with digital elements, the manufacturer shall inform the impacted users of the product with digital elements, and where appropriate all users, of that vulnerability or incident and, where necessary, of any risk mitigation and corrective measures that the users can deploy to mitigate the impact of that vulnerability or incident, where appropriate in a structured, machine-readable format	

		that is easily automatically processable…” ● Annex I(I)(c) “ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them” ● II(2): “[PDE shall be accompanied by] the single point of contact where information about vulnerabilities of the product with digital elements can be reported and received, and where the manufacturer’s policy on coordinated vulnerability disclosure can be found” ● II(7): “[PDE shall be accompanied by] the type of technical security support offered by the manufacturer and the end-date of the support period during which users can expect vulnerabilities to be handled and to receive security updates;” (not mapped by us) ● VII(2)(b): “[tech doc includes] necessary information and specifications of the vulnerability handling processes put in place by the manufacturer, including the software bill of materials, the coordinated vulnerability disclosure policy, evidence of the provision of a contact address for the reporting of the vulnerabilities and a description of the technical solutions chosen for the secure distribution of updates;" (not mapped by us) ● VII(6): “reports of the tests carried out to verify the conformity of the product with digital elements and of the vulnerability handling processes with the applicable essential cybersecurity requirements as set out in Parts I and II of Annex I;” ○ Note that this requires tests, and reports of tests, of the vulnerability handling processes ● VIII(II)(3.4) “the supporting evidence for the adequacy	

		of the technical design and development solutions and vulnerability handling processes. This supporting evidence shall mention any documents that have been used, in particular where the relevant harmonised standards or technical specifications have not been applied in full. The supporting evidence shall include, where necessary, the results of tests carried out by the appropriate laboratory of the manufacturer, or by another testing laboratory on its behalf and under its responsibility." These CRA vulnerability handling requirements appear nowhere is Annex I part II, yet by omitting them, it is manifestly incorrect that complying with this document could lead to compliance with the CRA's vulnerability handling requirements.	
Annexes	Technical	The Forum of Incident Response and Security Teams (FIRST) is a key leader in in incident response, and its materials are widely used. We were surprised to see practically no reference to FIRST, other than an oblique reference in 5.3.4.1 to the TLP (Traffic Light Protocol). There should be an additional annex identifying the mapping to their materials, and then any important omissions identified by that mapping should be addressed.	Add an annex with mappings and citations to FIRST, at least its PSIRT Services Framework and its CSIRT Services Framework. If that mapping indicates additional weaknesses in the standard, address them.